CONDENSED BRIEF · PRODUCT AND ENGINEERING

Role & Access Control and Designation Management

Five pages covering the logic, functionality and decisions that matter — condensed from the 19-page source-verified guide.

Document VK-RCD-MGT-001 · v1.0 · 13 November 2026 · evidence: direct inspection of the Vikasita Keralam repository

7	29	4	1	6	62
permission modules	permission actions	data access scopes	role value per user	organisation levels	seeded designations

What the module does

The Role & Access area decides what an administrator can assign and what a signed-in user may see or change. It maintains a role catalogue, a seven-module permission matrix, per-module record visibility, bulk user assignment, and a separate designation catalogue tied to organisation levels.

Four concepts are deliberately independent: **role** (system permissions), **designation** (organisational identity), **organisation level** (position in the hierarchy) and **data scope** (whose records). A designation never grants access on its own, and a data scope never grants an action.

How an access decision is meant to resolve

```
1  session valid          4  module permission exists   7  organisation / location scope matches
2  user account active    5  specific action permitted  8  allow, otherwise deny
3  role resolved          6  data scope resolved        9  record the decision where audit is required
```

Only steps 1–6 exist in the client today. Steps 7–9 have no verified server-side implementation.

How to read the status labels

Label	Meaning
Implemented	Verified in source and reachable in the current UI or client workflow.
Partially implemented	Workflow exists but validation, enforcement or consistency is missing.
Stored in client	The value is captured, but no runtime or server-side enforcement was found.
Not implemented / not verified	No corresponding implementation was found in the repository.

Where it lives in the app

```
Admin Settings   /admin/settings
  Roles and Control      Roles tab, Users tab, assignment drawer
  Designations           designation catalogue and organisation level filter
  Organisational charts  hierarchy reference
  Location management    organisation units and user-location assignment
Role authoring  /admin/settings_/new-role, RoleEditorDialog, /admin/settings_/assign-role
Mobile mirror   MobileRolesPage, MobileRolePermissionMatrix, MobileSettingsPage
```

What the remaining pages cover

- **Page 2 — role lifecycle:** authoring surfaces, create fields, validation, propagation, duplicate, status and delete behaviour.
- **Page 3 — permission logic:** the seven modules and 29 actions, prerequisite cascade, permission key format, the four data scopes and the administrative layer.
- **Page 4 — people and hierarchy:** user assignment and its defect, the designation model, the two catalogues, six organisation levels and the region mismatch.
- **Page 5 — delivery:** implementation status, priority gaps, the files that carry the logic and the decisions needed before build.

Documentation only — prototype, not production authorisation

Every role, permission, data scope and designation record is held in browser **localStorage**. No backend API, database table, server guard or query-level data filter was verified. Client-side checks must not be treated as a security boundary.

1 Role lifecycle

A role is a named bundle of module permissions, per-module data scopes and optional administrative permissions. Three authoring surfaces exist and they are **not equivalent**.

Authoring surfaces

Surface	Where	What it can set
Full-page editor	`/admin/settings_/new-role`	Name, description, permissions, data scope. Writes the **State** level only and no administrative permissions on create.
Editor dialog	`RoleEditorDialog.tsx`	Name, description, allowed levels, module matrix, data scopes and administrative permissions.
Mobile form	`MobileRolesPage.tsx`	Name, status, permissions and data scopes; also duplicate, delete and worker assignment.

New role fields

Field	Req.	Verified behaviour
Role name	Yes	Blank rejected. Dialog and mobile reject duplicates case-insensitively; the full-page save handler does **not** run the same duplicate check.
Status	No	Active or Inactive. The full-page create handler always initialises Active.
Allowed assignment levels	Dialog only	State, Region, Organisational District, Mandalam, Area, Booth. The full-page create handler writes `state` only.
Module permissions	Yes	At least one action. View is added automatically as a prerequisite.
Data access	Yes	Defaults to Own Records per module; several scopes can be combined.
Administrative permissions	No	Role management, Access assignment, Access delegation. The full-page create handler writes an empty list.

Lifecycle rules developers must preserve

- **View before action.** Create, Edit and Delete require View in the same module; Schemes: View Details requires View List. Removing View removes every dependent permission.
- **Duplicate, not clone.** The copy is named *<role> (copy)*, then *(copy) 2*, *3*…; permissions, scopes and administrative rights are copied and the copy starts with zero users.
- **Edits propagate.** Permissions are read through the role at runtime — there is no per-user snapshot, so an edit immediately changes every holder.
- **Deactivate is a guard, not a delete.** Existing holders keep the role; new assignments are blocked and the administrator must acknowledge the affected count.
- **Delete has no remediation.** Confirmation is shown, but holders are not reassigned and users keep a stale role label.

Built-in and seeded roles

Role	Level	Administrative permissions	Users
Admin `system_state_admin`	State	Management, assignment, delegation	—
Sub Admin `system_sub_admin`	State	Management, assignment	—
Support Admin `system_support_admin`	State	None	—
State Admin (preset)	State	Management, assignment, delegation	4
District Admin (preset)	District	Access assignment	14
Constituency Admin (preset)	Assembly Constituency	Access assignment	42
Local Body Admin (preset)	Local Body	Access assignment	118
Booth Admin (preset)	Booth	None	326
User / party_worker (preset)	Ward, Booth, Party Unit	None	1,284

The first three are page-level built-ins; the rest are seeded presets. User counts are seed data, not live employment figures.

Two confirmed exceptions to system-role protection

The three page-level roles above **can be deleted** unlike other built-in roles, and a role created from the full-page route is locked to State with no administrative permissions.

2 Permission and data-scope logic

Module permissions answer **what** a role can do; data access answers **whose** records the action may touch. They are configured independently for every module.

Seven modules, 29 actions

Module	Permission ID	Actions	Prerequisite
Applicant Profile	`applicant_profile`	View, Create, Edit, Delete	View first
Applications	`applications`	View, Create, Edit, Delete	View first
Schemes	`schemes`	View List, View Details, Create, Edit, Delete	List → Details → C/E/D
Role & Access	`roles`	View, Create, Edit, Delete	View first
Designation	`designations`	View, Create, Edit, Delete	View first
Users	`party_workers`	View, Create, Edit, Delete, View Teams	View first
Request / help desk	`help_desk`	View, Assign Team Member, Respond/Reply	View first

How permissions are stored

```
module.action                schemes.view_details    party_workers.view_teams
module.scope.action          applications.below_level.view    applications.own_records.edit
```

The matrix shows Create / View / Edit / Delete; module-specific actions are surfaced as secondary controls (Schemes view list and details, Users View Teams, Request assign and reply). Select All exists for modules and per-module All for data access, and individual actions can be removed afterwards.

Four data-access scopes

Scope	Intended meaning	Behaviour today
Own Records	Records created by or explicitly assigned to the signed-in user	Default on every module; stored in `dataAccess`.
Below My Level	Records of subordinate organisational units	Selectable and stored; no query-level enforcement verified.
Same Level – Peers	Records of peer units at the same level	Selectable and stored; no query-level enforcement verified.
Above My Level	Records of superior organisational units	Defined in the model and available on the full assign-role route, but hidden from most editors.

- Scopes combine per module and are persisted in a canonical order; a module can carry Own + Below + Peers.
- Role dialog, user editor and mobile matrix expose Own, Below and Peers — **Above is omitted**, so behaviour differs by authoring path.
- Boundaries are undefined and need approval: does Below include all descendants, are peers one unit or the whole level, and are read, edit, delete and export filtered independently?

Administrative permissions, not module actions

Permission	Grants
Role management	Create, edit and delete roles and change their status
Access assignment	Assign roles to users and maintain their role value
Access delegation	Allow another administrator to manage access in turn

Admin holds all three, Sub Admin holds management and assignment, Support Admin holds none, and a role created from the full-page editor starts with none.

> **Keep the three layers separate**
> **Module permission** = what may be done. **Data scope** = whose records it may touch. **Administrative permission** = the ability to manage roles, assign roles or delegate access, which is not an ordinary module action.

3 User assignment, designations and hierarchy

User assignment

- **One role value per user.** The user record stores a single `assignedRole`; a multi-role membership model was not verified.
- **Bulk assignment.** The drawer searches by name, designation, constituency or district and filters by designation, region, organisational district, mandalam, area and booth, with select/deselect all. Saving updates the role's `assignedUsers` count.
- **Per-user overrides** are possible on `/admin/settings_/assign-role`, which also exposes all four data scopes.
- **Confirmed defect:** in the desktop drawer, deselecting a user who already holds the role reassigns them to **Sub Admin** instead of leaving them unassigned — an unintended privilege change.

Designation model

Field	Rule
Designation name	Required. No case-insensitive duplicate check was verified.
Organisation level	Required; State, Region, Organisational District, Mandalam, Area or Booth. Filters the designation picker shown when assigning a user.
Parent designation	Optional and must be at the same level. Rank is derived as `parent.rank + 1`; a top-level designation gets rank 1.
Status and order	Active or Disabled; Disabled hides the option from new assignment. Move up/down changes display order within the filtered catalogue.
Deletion	Removes or hides the option after confirmation; the desktop handler does **not** check for assigned users, so references can dangle.
Storage	`vikasita_managed_designations_v1` on desktop; separate keys for mobile custom records, overrides and hidden IDs.

Two catalogues, one hierarchy

Source	Count	Divergent labels to note
Desktop Designation Master	32	President, Vice President, Executive Member, Kendra Convener, Worker
Shared party-designation register	30	State President, District President, Karyakarta, Booth Agent

Neither list is canonical: the same organisational role can appear under different names in the designation master, the party register, the new-user picker and mobile. **One catalogue must be approved and migrated before production.**

Hierarchy: State → Region → Organisational District → Mandalam → Area → Booth. Reference figures in the location master are 1 state, 30 organisational districts, 140 constituency-based mandalams, configurable areas and 25,000+ booths.

Known inconsistency: the region layer is defined as three regions (South, Central, North) in party data and user forms, but as four rows (Northern, Central, Southern, Far Southern) in the location master. District totals still reconcile at 30.

Role versus designation

Dimension	Role	Designation
Purpose	Functional system access	Organisational identity
Grants permissions	Yes, module and administrative	No — access requires a role
Organisation link	Through allowed assignment levels	One organisation level per designation
On deletion	Users must be reviewed; no automatic fix	Assigned users are not remediated

4 Delivery status, gaps and developer handoff

Implementation status

Requirement	Status	Evidence
Role catalogue, search, status, counts	Implemented	RoleAccessSettings.tsx
Create a custom role	Partially	Two desktop paths differ in fields
Edit name, description, permissions, scope	Implemented	RoleEditorDialog, new-role
Unique role names	Partially	Full-page save has no duplicate check
7 modules / 29 actions with prerequisites	Implemented	party-workers.ts
Per-module data access	Stored in client	RoleDataAccess, dataAccessOptions
Duplicate, activate, deactivate a role	Implemented	nextRoleCopyName, status dialog
Delete a role safely	Partially	No assignment remediation
Multiple roles per user	Not implemented	Single assignedRole
Designation catalogue, level filter, rank	Implemented	Designation master, mobile screen
Duplicate designation prevention	Not verified	No duplicate check found
Protect designation delete when assigned	Not implemented	No assignment check
Server-side access enforcement	Not verified	No API or query guard
Audit trail for access changes	Not implemented	No audit store

Confirmed gaps by priority

Priority	Gap and required action
Critical	No server-side RBAC and no query-level scope filtering — enforce module, action and scope in every API and list query. All records are device-local localStorage.
Critical	Deselecting a role holder reassigns them to Sub Admin — replace with an explicit Unassigned or reviewed-transfer flow.
High	No audit log; role and designation deletion ignore assigned users; two designation catalogues; two role editors with different fields; Above scope hidden inconsistently.
Medium	Single role per user; duplicate designation names allowed; region grouping defined as both three and four regions.

Files that carry the logic

File	Responsibility
`src/data/role-management.ts`	Role model, status, admin permissions, data-access options, scoped keys, copy names, built-ins, storage
`src/data/party-workers.ts`	7 modules / 29 actions, prerequisites, assignment levels, presets, party designations
`src/components/admin/RoleAccessSettings.tsx`	Role and user tables, assignment drawer, designation master, status dialogs, import/export
`src/components/admin/RoleEditorDialog.tsx`	Dialog editor: levels, module matrix, data access, administrative permissions
`src/routes/admin.settings_.new-role.tsx`	Full-page editor: State-only level, no administrative permissions on create
`src/routes/admin.settings_.assign-role.tsx`	Per-user overrides and all four data scopes
`src/components/admin/MobileRolesPage.tsx`	Mobile role list, create/edit, duplicate, delete, worker assignment
`src/components/admin/MobileSettingsPage.tsx`	Mobile designation catalogue and settings mirror

Decisions required before a production build

1. One role plus overrides, or true multi-role? 2. Exact meaning of Below / Peer / Above across the six levels? 3. Can a designation ever imply a default role? 4. Which service replaces localStorage, and who owns migration? 5. Which changes require dual approval or audit?

Prepared from direct inspection of the listed files. No application code, route, permission, designation, mapping, API or database record was modified. The full 19-page guide remains the detailed reference.